



Task: Theory + Practical Security Assessment

Cybersecurity Internship – CyArt

Date: 13th Mar 2026

Prepared by: Akash Bangera



Table of Contents

1. Understanding Security Assessment.....	3
1.1 Objective:	3
1.2 Security Assessment:	3
1.3 Frameworks:.....	3
1.4 Types of Security Testing	4
2. VAPT Methodology	5
2.1 Objective:	5
2.2 Methodology Phases:	5
3. Security Standards & Compliance.....	6
3.1 Objective:	6
3.2 Standards:	6
4. Risk Assessment Basics	7
4.1 Objective:	7
4.2 CVSS Scoring System:.....	7
4.3 Risk Matrix.....	9
5. Common Vulnerabilities	10
5.1 Objective:	10
5.2 Network Vulnerabilities:	10
5.3 Web Vulnerabilities:	10
6. Documentation Fundamentals	11
6.1 Objective:	11
6.2 Documentation Tools:.....	11
7. Sources Consulted	12
8. Conclusion	13



1. Understanding Security Assessment

1.1 Objective:

To understand what a security assessment is and why it is necessary to do a security assessment at organization and identify security weaknesses using frameworks.

1.2 Security Assessment:

Security Assessment is the process of identifying, analyzing and evaluating weaknesses or security issues in systems such as networks, servers, applications, databases, and operating systems.

Purpose:

To identify security weaknesses and mitigate them to secure the organisation's systems from cyber attacks such as hacking, malware, phishing and unauthorized access.

1.3 Frameworks:

NIST (National Institute of Standards and Technology) provides cybersecurity standards and frameworks used worldwide to improve the security posture of organisations.

Common NIST frameworks used in security assessment

- NIST Cybersecurity Framework (CSF)
- NIST SP 800-53
- NIST Risk Management Framework (RMF)

These frameworks help organizations to identify, protect, detect, respond and recover from cyber threats.



1.4 Types of Security Testing

1. Vulnerability Assessment:

A vulnerability assessment is a process of identifying a list of security vulnerabilities. This can be done through automated scanning tools, which are used for this type of testing.

Tools:

- Nessus
- OpenVas
- Nikto
- Qualys

2. Penetration Testing:

Penetration Testing is the process of actively exploiting the list of vulnerabilities that is identified in the process of vulnerability assessment. This can be done through the manual way.

Tools:

- Metasploit
- Nmap
- Burpsuite
- SQLMap

3. Compliance Testing:

Compliance Testing is the process of checking whether the organization follows security standards, like

- NIST
- ISO 27001
- PCI-DSS
- CIS Benchmarks
- HIPAA
- GDPR



2. VAPT Methodology

2.1 Objective:

The objective of the vulnerability assessment and penetration testing (VAPT) methodology is to follow a systematic approach to identify, analyze and report security vulnerabilities.

2.2 Methodology Phases:

1. Planning

In this phase, the scope, objectives, and target of the assessment are defined. The testing boundaries, rules of engagement and authorized system are established before starting the assessment

Tools:

Dradis CE

2. Discovery

In this phase, the target system are scanned to gather information about ports, services, versions, technologies and to identify security vulnerabilities.

Tools:

Nmap

3. Attack

In this phase, identified vulnerabilities are validated and tested manually to determine whether they can be exploited.

Tools:

Metasploit Framework

4. Reporting



In this phase, all findings are documented in a detailed vulnerability assessment and penetration testing report. These report includes executive summary, vulnerability description, proof of concept, risk assessment and remediation steps.

Tools:
Word

3. Security Standards & Compliance

3.1 Objective:

To ensure that systems, processes, and security controls comply with applicable regulations, standards, and policies by utilizing frameworks, guidelines, tools, and documentation resources.

3.2 Standards:

1. General Data Protection Regulation (GDPR)

A Data protection regulation created by the European Union to protect personal data and privacy of individuals. It requires organizations to securely handle personal information, obtain user consent, report data breaches, and give individuals right over their data.

2. Health Insurance Portability and Accountability Act (HIPAA)

A U.S regulation that protects sensitive healthcare information (Protected Health Information) PHI. It requires healthcare organizations to implement administrative, physical and technical safeguards to ensure the confidentiality and security of medical information.

3. ISO/IEC 27001

An international standard for information security management system (ISMS) published by the International Organization for Standardization. It provides a



framework for managing risks, implementing security controls, and protecting organizational information.

4. Payment Card Industry Data Security Standard (PCI-DSS)

A security standard developed by the Payment Card Industry Security Standards Council to protect payment card information. It requires organizations that handle credit or debit card data to implement security measures such as encryption, access control, and regular security monitoring.

4. Risk Assessment Basics

4.1 Objective:

The goal of vulnerability prioritizing is to identify which vulnerabilities should be fixed first based on their risk and impact. This can be identified using the Common Vulnerability Scoring System (CVSS).

4.2 CVSS Scoring System:

The Common Vulnerabilities Scoring System is globally used to measure the severity of security vulnerabilities.

CVSS Score Range:

Score	Severity
0.0	None
0.1 - 3.9	Low
4.0 – 6.9	Medium
7.0 - 8.9	High
9.0 - 10.0	Critical



CVSS Calculator:

CVSS Calculator is a tool used to determine the severity score of a vulnerability. Security analyst use it during vulnerability assessment and penetration testing to prioritize the vulnerabilities to be fixed first based on severity.

The calculator evaluates factors such as

1. Attack Vector (AV)

How attackers takes access of the system

- Network
- Adjacent
- Local
- Physical

2. Attack Complexity (AC)

How difficult it is to exploit the vulnerability

- Low
- High

3. Privileges Required (PR)

Privileges required before exploiting

- None
- Low
- High

4. User Interaction (UI)

Whether the attack requires action to exploit

- None
- Required



5. Impact metrics

These measure damage to the system

- Confidentiality
- Integrity
- Availability

4.3 Risk Matrix

A Risk Matrix is a visual tool used to prioritize vulnerabilities or security risks based on two factors:

Likelihood: How likely the attack will happen

Impacts: How severe the damage will be if it happens

3x3 Risk Matrix:

Impact/Likelihood	Low	Medium	High
High Impact	Medium	High	High
Medium Impact	Low	Medium	High
Low Impact	Low	Low	Medium

Way to Derive Likelihood and Impact from CVSS Score:

CVSS Score	Likelihood	Impact
9 – 10	High	High
7 – 8.9	High	Medium
4 – 6.9	Medium	Medium
0 – 3.9	Low	Low



5. Common Vulnerabilities

5.1 Objective:

Identify security weaknesses in systems, networks, and web applications.

5.2 Network Vulnerabilities:

1. Open Ports:

Open ports show services running on the network. Open ports are not a weakness, but if unnecessary ports are open without any use, an attacker takes them as an advantage for further exploitation. Nmap tool is used to discover open ports.

2. Misconfiguration:

Security Misconfiguration happens when a network is not configured securely, leaving it vulnerable to attacks. eg. If the password is set as a default.

3. Weak Firewall Rules:

Weak firewall rules occur when a firewall is configured with insecure or overly permissive rules, allowing unauthorized traffic to access the network.

5.3 Web Vulnerabilities:

1. SQL Injection:

SQL injection is a web application vulnerability that occurs when attacker inserts malicious SQL query into an application's input field, which then executed by the database. This allows an attacker to alter or manipulate the data that is stored in the database.

2. Cross-Site Scripting (XSS)

An cross-site scripting is a web application vulnerability that occurs when the application allows attackers to inject malicious JavaScript code into web pages viewed by other users. When the victim accesses the affected page. The javascript



code executes in their browser and can steal sensitive information such as session cookies.

3. Insecure Direct Object Reference (IDOR)

Insecure Direct Object Reference (IDOR) is a web application vulnerability that occurs when an application exposes internal objects, such as files or user records, through user-controlled input without proper authorization checks. This allows an attacker to manipulate parameters such as (user ID in URLs) to access or modify data of other users without authorization.

6. Documentation Fundamentals

6.1 Objective:

To Learn how to create and organize security assessment reports using documentation tools

6.2 Documentation Tools:

Dradis CE: Dradis CE is an open-source tool used by penetration testers and security analysts to document and manage vulnerabilities during security assessments. It allows teams to store findings, evidence, screenshots, and notes in one centralized place.

Cherry Tree: Cherry Tree is an open-source hierarchical note-taking application used to organize and store information in a tree structured format. It allows users to save text, code snippets, commands, images, and technical notes, making it useful for documenting findings during security assessments.



7. Sources Consulted

1. Security Assessment

- ▶ <https://www.cbts.com/blog/what-is-a-security-assessment/>
- ▶ <https://www.sisainfosec.com/blogs/10-types-of-security-testing-techniques/>
- ▶ <https://www.nist.gov/cyberframework>

2. VAPT Methodology

- ▶ <https://meta-techs.net/vapt-methodology/>
- ▶ <https://www.eccouncil.org/cybersecurity-exchange/penetration-testing/penetration-testing-phases/>

3. Security, Standards & Compliance

- ▶ <https://www.nist.gov/cyberframework>
- ▶ <https://www.dataguard.com/cyber-security/standards/>

4. Risk Assessment Basics

- ▶ <https://www.eccouncil.org/cybersecurity-exchange/executive-management/5-steps-to-perform-cyber-security-risk-assessment/>
- ▶ <https://www.first.org/cvss/calculator/4.0>
- ▶ <https://www.fortinet.com/resources/cyberglossary/common-vulnerability-scoring-system>

5. Common Vulnerabilities

- ▶ <https://www.cobalt.io/blog/common-network-security-vulnerabilities>
- ▶ <https://owasp.org/Top10/2025/>

6. Documentation Fundamentals

- ▶ <https://dradis.com/>
- ▶ <https://www.kali.org/tools/cherrytree/>
- ▶ <https://www.giuspen.net/cherrytree/>



8. Conclusion

Security assessment combines knowledge of security concepts, practical testing methods, and proper documentation to identify weaknesses in systems and applications. Understanding topics such as security assessment processes, VAPT methodology, risk evaluation, and common vulnerabilities helps security professionals systematically analyze potential security risks.

Using tools like Nmap, Metasploit Framework, and OpenVAS allows testers to detect vulnerabilities and simulate attacks in controlled environments. Documentation tools such as Dradis CE and CherryTree help organize findings and create clear security reports.

By following structured methodologies, applying recognized security standards, and prioritizing vulnerabilities using risk scoring methods, organizations can better understand their security posture and take appropriate steps to reduce risks.



METASPLOITABLE 3 VULNERABILITY ASSESSMENT REPORT

**Prepared by
Akash Bangera**



Table of Contents

1. Introduction	3
1.1 Scope of Test	3
1.2 Purpose of Test	3
1.3 Type of Test	3
2. Executive Summary	4
3. Detailed Analysis	5
3.1 Host Information	5
3.2 Scan Results	5
3.3 Vulnerabilities	8
4. Risk Assessment	13
5. Recommendations	15



1. Introduction

1.1 Scope of Test

The scope of this security assessment included the complete **Metasploitable 3 virtual machine**, which was configured as the target system for vulnerability assessment. The objective of the test was to identify potential security weaknesses present within the system and evaluate the overall security posture of the environment.

The assessment covered both network-level services and web applications running on the target machine. All testing activities were conducted on the target system within the defined scope using the following IP address:

Target IP Address: 192.168.0.127

1.2 Purpose of Test

The main purpose of this security assessment was to examine the **Metasploitable 3 machine** in order to identify any possible security weaknesses or vulnerabilities present in the system. The test was conducted to determine whether the target machine contains misconfigurations, insecure services, or known vulnerabilities that could potentially be exploited by an attacker.

Another objective of this assessment was to evaluate the possible impact of the discovered vulnerabilities on the system. By understanding how these weaknesses could be exploited, it becomes easier to determine the level of risk they pose to the system and its services.

In addition, the assessment aimed to provide practical recommendations for mitigating the identified vulnerabilities. These recommendations help improve the security of the system by reducing the chances of unauthorized access, data compromise, or service disruption.

1.3 Type of Test

The security assessment conducted on the target system followed the **Black Box Testing** approach. In this approach, the tester does not have prior knowledge about



the internal configuration, source code, or system architecture of the target environment. The assessment is performed from an external perspective, similar to how a real attacker would attempt to discover and exploit vulnerabilities. For this test, the IP address of the target machine was the only information provided at the beginning of the assessment. Using this information, the tester conducted activities such as reconnaissance, network scanning, and service enumeration to identify active services, open ports, and potential security weaknesses within the system.

2. Executive Summary

A vulnerability assessment was conducted to evaluate the security posture of the Metasploitable 3 system and identify potential weaknesses that could be exploited by attackers. The assessment was performed by using open-source cybersecurity tools, including Kali Linux, nmap, and vulnerability scanning tools such as Nessus and Nikto in a controlled lab environment.

The objective of the assessment is to identify security vulnerabilities, misconfigurations and outdated services that may lead to compromise of the system. The scanning process analysed open ports and service versions of the target Metasploitable 3 system.

The result of the vulnerability scanning with Nessus and Nikto revealed many security vulnerabilities with severity levels such as Critical, High, Medium, Low and Informational.

If left unaddressed, these vulnerabilities could increase the risk of unauthorized access, data exposure, or system compromise. Therefore, it is recommended that critical and high-severity vulnerabilities be prioritized for immediate remediation, followed by medium and low-severity findings.



3. Detailed Analysis

3.1 Host Information

Machine name: Metasploitable 3

IP address: 192.168.0.127

3.2 Scan Results

Nmap: To discover open ports and service information of the target system

```
# Nmap 7.98 scan initiated Thu Mar 5 09:14:11 2026 as: /usr/lib/nmap/nmap --privileged -A -p- -T5 -oN metasploitable3 192.168.0.127
Nmap scan report for 192.168.0.127
Host is up (0.0014s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|_ 2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|_ 256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_ 256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-ls: Volume /
|_  SIZE  TIME             FILENAME
|_  -    2020-10-29 19:37 chat/
|_  -    2011-07-27 20:17 drupal/
|_ 1.7K  2020-10-29 19:37 payroll_app.php
|_  -    2013-04-08 12:06 phpmyadmin/
|_
|_ http-title: Index of /
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
|_ http-title: Home - CUPS 1.7.2
|_ http-methods:
|_ Potentially risky methods: PUT
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-robots.txt: 1 disallowed entry
|_ /
3000/tcp  closed ppp
3306/tcp  open  mysql        MySQL (unauthorized)
3500/tcp  open  http         WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))
|_ http-server-header: WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
|_ http-title: Ruby on Rails: Welcome aboard
|_ http-robots.txt: 1 disallowed entry
|_ /
6697/tcp  open  irc          UnrealIRCd
8080/tcp  open  http         Jetty 8.1.7.v20120910
|_ http-server-header: Jetty(8.1.7.v20120910)
|_ http-title: Error 404 - Not Found
8181/tcp  closed intermapper
MAC Address: 08:00:27:CB:42:FC (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 - 4.4 (94%), Linux 3.13 (94%), Android 8 - 9 (Linux 3.18 - 4.4) (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404, irc.TestIRC.net; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Nmap scan result



Nikto: To identify security issues of a web application

```
- Nikto v2.5.0
+ Target IP: 192.168.0.127
+ Target Hostname: 192.168.0.127
+ Target Port: 80
+ Start Time: 2026-03-08 00:28:10 (GMT-5)

+ Server: Apache/2.4.7 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ /: Directory indexing found.
+ Apache/2.4.7 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /./: Directory indexing found.
+ /./: Appending './' to a directory allows indexing.
+ //: Directory indexing found.
+ //: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /%2e/: Directory indexing found.
+ /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: http://www.securityfocus.com/bid/2513
+ ///: Directory indexing found.
+ /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'.
+ /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'.
+ /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.4.5.
+ /phpmyadmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpmyadmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpmyadmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpmyadmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ 8911 requests: 0 error(s) and 22 item(s) reported on remote host
+ End Time: 2026-03-08 00:29:29 (GMT-5) (79 seconds)

+ 1 host(s) tested
```

Nikto scan result

Nessus: To identify overall security issues of the system

metasploitable-3									
Back to All Scans									
Configure Audit T									
Hosts 1 Vulnerabilities 54 Remediations 4 Notes 8 History 1									
Filter Search Vulnerabilities 54 Vulnerabilities									
Sev	CVSS	VPR	EPSS	Name	Family	Count			
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (14.04.x)	General	1			
CRITICAL	9.8	7.4	0.9393	ProFTPD mod_copy Information Disclosure	FTP	1			
MEDIUM	6.5	4.0	0.0596	IP Forwarding Enabled	Firewalls	1			
MEDIUM	5.3			Browsable Web Directories	CGI abuses	1			
MEDIUM	4.3 *			Web Application Potentially Vulnerable to Clickjacking	Web Servers	1			
LOW	2.1 *	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1			
INFO				Backported Security Patch Detection (FTP)	General	1			
INFO				Backported Security Patch Detection (WWW)	General	1			
INFO				Common Platform Enumeration (CPE)	General	1			
INFO				Device Type	General	1			

Nessus scan result



☐	INFO	Eclipse Jetty Web Server Detection	Web Servers	1	⊙	✎
☐	INFO	Embedded Web Server Detection	Web Servers	1	⊙	✎
☐	INFO	Ethernet Card Manufacturer Detection	Misc.	1	⊙	✎
☐	INFO	Ethernet MAC Addresses	General	1	⊙	✎
☐	INFO	FTP Server Detection	Service detection	1	⊙	✎
☐	INFO	Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure	Windows	1	⊙	✎
☐	INFO	Nessus Scan Information	Settings	1	⊙	✎
☐	INFO	OS Fingerprints Detected	General	1	⊙	✎
☐	INFO	OS Identification	General	1	⊙	✎
☐	INFO	OS Security Patch Assessment Not Available	Settings	1	⊙	✎
☐	INFO	Patch Report	General	1	⊙	✎
☐	INFO	Samba Server Detection	Service detection	1	⊙	✎
☐	INFO	Samba Version	Misc.	1	⊙	✎
☐	INFO	Target Credential Status by Authentication Protocol - No Credentials Provided	Settings	1	⊙	✎
☐	INFO	TCP/IP Timestamps Supported	General	1	⊙	✎

Nessus scan result

☐	INFO				TCP/IP Timestamps Supported	General	1	⊙	✎
☐	INFO				Traceroute Information	General	1	⊙	✎
☐	INFO				Web mirroring	Web Servers	1	⊙	✎
☐	INFO				WebDAV Directory Enumeration	Web Servers	1	⊙	✎
☐	MIXED	...	...	...	📁 Phpmyadmin (Multiple Issues)	CGI abuses	2	⊙	✎
☐	MIXED	...	...	...	📁 Openssd Openssh (Multiple Issues)	Misc.	2	⊙	✎
☐	MIXED	...	...	...	📁 PHP (Multiple Issues)	Web Servers	2	⊙	✎
☐	MIXED	...	...	...	📁 SMB (Multiple Issues)	Misc.	2	⊙	✎
☐	INFO	...	...	...	📁 Apache HTTP Server (Multiple Issues)	Web Servers	2	⊙	✎
☐	INFO	...	...	...	📁 SMB (Multiple Issues)	Windows : User management	2	⊙	✎
☐	INFO	...	...	...	📁 SSH (Multiple Issues)	General	2	⊙	✎
☐	INFO	...	...	...	📁 SSH (Multiple Issues)	Service detection	2	⊙	✎
☐	INFO	...	...	...	📁 TLS (Multiple Issues)	General	2	⊙	✎
☐	INFO				External URLs	Web Servers	2	⊙	✎
☐	INFO				Remote Services Not Using Post-Quantum Ciphers	General	2	⊙	✎

Nessus scan result



☐	INFO	Web Application Sitemap	Web Servers	2	⊙	✎
☐	MIXED	Drupal (Multiple Issues)	CGI abuses	3	⊙	✎
☐	MIXED	TLS (Multiple Issues)	Service detection	3	⊙	✎
☐	INFO	MySQL Server Detection	Databases	3	⊙	✎
☐	INFO	HTTP (Multiple Issues)	CGI abuses	4	⊙	✎
☐	INFO	Web Application Cookies Not Marked HttpOnly	Web Servers	4	⊙	✎
☐	INFO	Web Application Cookies Not Marked Secure	Web Servers	4	⊙	✎
☐	MIXED	Web Server (Multiple Issues)	Web Servers	5	⊙	✎
☐	MIXED	SSH (Multiple Issues)	Misc.	6	⊙	✎
☐	MIXED	SSL (Multiple Issues)	General	7	⊙	✎
☐	INFO	SMB (Multiple Issues)	Windows	8	⊙	✎
☐	INFO	Nessus SYN scanner	Port scanners	8	⊙	✎
☐	INFO	Service Detection	Service detection	8	⊙	✎
☐	INFO	HTTP (Multiple Issues)	Web Servers	9	⊙	✎
☐	MIXED	PHP (Multiple Issues)	CGI abuses	29	⊙	✎

Nessus scan result

3.3 Vulnerabilities

1. ProFTPD mod_copy Information Disclosure

Description

The remote host is running a version of ProFTPD that is affected by an information disclosure vulnerability in the mod_copy module due to the SITE CPFR and SITE CPTO commands being available to unauthenticated clients. An unauthenticated, remote attacker can exploit this flaw to read and write to arbitrary files on any web accessible path on the host.

Solution

Upgrade to ProFTPD 1.3.5a / 1.3.6rc1 or later.

Risk Factor

Critical

CVSS v4.0 Base Score

9.8



2. Drupal Coder Module Deserialization RCE

Description

The version of Drupal running on the remote web server is affected by a remote code execution vulnerability in the Coder module, specifically in file `coder_upgrade.run.php`, due to improper validation of user-supplied input to the `unserialize()` function. An unauthenticated, remote attacker can exploit this via a specially crafted request, to execute arbitrary PHP code.

Solution

Upgrade the Coder module to version 7.x-1.3 / 7.x-2.6 or later.

Alternatively, remove the entire Coder module directory from any publicly accessible website.

Risk Factor

Critical

CVSS v4.0 Base Score

10.0

3. Drupal Database Abstraction API SQLi

Description

The remote web server is running a version of Drupal that is affected by a SQL injection vulnerability due to a flaw in the Drupal database abstraction API, which allows a remote attacker to use specially crafted requests that can result in arbitrary SQL execution. This may lead to privilege escalation, arbitrary PHP execution, or remote code execution.

Solution

Upgrade to version 7.32 or later.

Risk Factor

High

CVSS v4.0 Base Score

7.5



4. SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

Risk Factor

High

CVSS v4.0 Base Score

7.5

5. PHP 5.4.x < 5.4.12 Information Disclosure

Description

According to its banner, the version of PHP 5.4.x installed on the remote host is prior to 5.4.12. It is, therefore, potentially affected by an information disclosure in the file 'ext/soap/php_xml.c' related to parsing SOAP 'wsdl' files and external entities that could cause PHP to parse remote XML documents defined by an attacker. This could allow access to arbitrary files. (CVE-2013-1824)

Note that this plugin does not attempt to exploit the vulnerabilities but, instead relies only on PHP's self-reported version number.

Solution

Apply the vendor patch or upgrade to PHP version 5.4.17 or later.



Risk Factor

medium

CVSS v4.0 Base Score

5.3

6. IP Forwarding Enabled

Description

The remote host has IP forwarding enabled. An attacker can exploit this to route packets through the host and potentially bypass some firewalls / routers / NAC filtering.

Unless the remote host is a router, it is recommended that you disable IP forwarding.

Solution

On Linux, you can disable IP forwarding by doing :

```
echo 0 > /proc/sys/net/ipv4/ip_forward
```

On Windows, set the key 'IPEnableRouter' to 0 under

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters

On Mac OS X, you can disable IP forwarding by executing the command :

```
sysctl -w net.inet.ip.forwarding=0
```

For other systems, check with your vendor.

Risk Factor

Medium

CVSS v4.0 Base Score

6.5



Vulnerability	severity	CVSS Score	Impact
Canonical Ubuntu Linux SEoL (14.04)	critical	10.0	Ubuntu 14.04 has reached End-of-Life and no longer receives security updates from Canonical, exposing the system to unpatched vulnerabilities and increasing the risk of system compromise.
ProFTPD mod_copy Information Disclosure	critical	9.8	The ProFTPD mod_copy module vulnerability allows an attacker to copy arbitrary files on the server, potentially leading to sensitive information disclosure and unauthorized access to critical system files.
phpMyAdmin prior to 4.8.6 SQLi vulnerability (PMASA-2019-3)	critical	9.8	phpMyAdmin versions prior to 4.8.6 contain an SQL Injection vulnerability (PMASA-2019-3) that could allow an authenticated attacker to execute arbitrary SQL queries and potentially access or modify database data
Drupal Coder Module Deserialization RCE	critical	10.0	The Drupal Coder Module contains a deserialization vulnerability that could allow an attacker to execute arbitrary code on the server, potentially leading to full system compromise.
PHP Unsupported Version Detection	critical	10.0	The detected PHP version is unsupported and no longer receives security updates, exposing the application to known vulnerabilities that could lead to system compromise or unauthorized access.
PHP 5.4.5 < 5.4.39 Multiple Vulnerabilities	critical	9.8	PHP versions between 5.4.5 and 5.4.39 contain multiple known vulnerabilities that could allow attackers to execute arbitrary code, cause denial of service, or compromise the affected system.

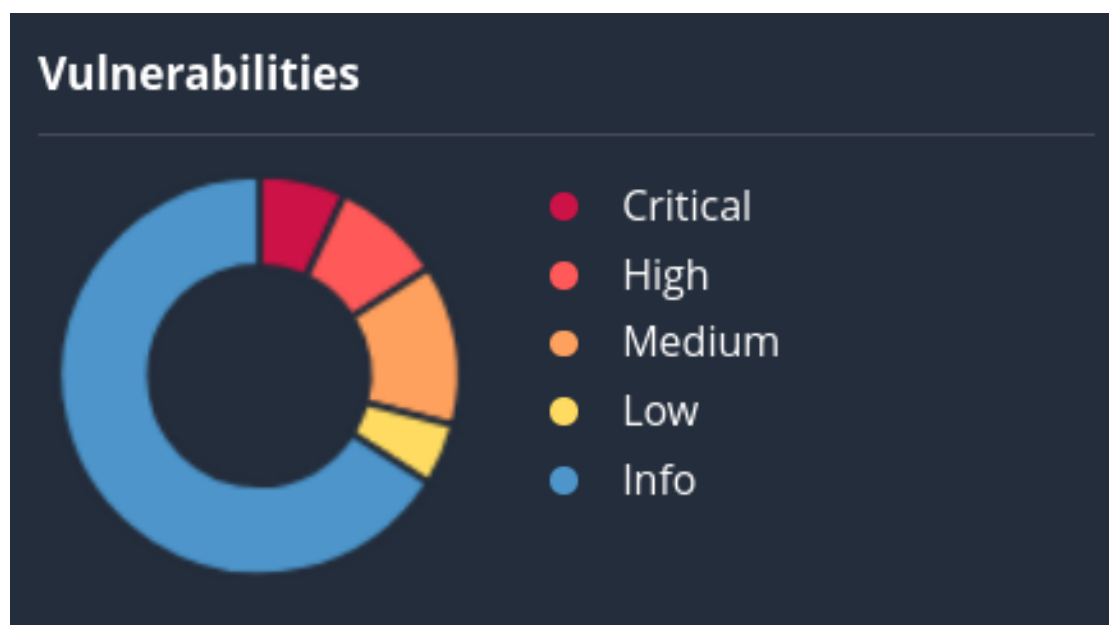


PHP 5.4.5 < 5.4.17 Buffer Overflow	critical	9.3	PHP versions between 5.4.5 and 5.4.17 contain a buffer overflow vulnerability that could allow attackers to cause denial of service or potentially execute arbitrary code on the affected system.
PHP 5.4.5 < 5.4.36 'process_nested_data' RCE	high	7.5	PHP versions between 5.4.5 and 5.4.36 are vulnerable to a process_nested_data Remote Code Execution (RCE) vulnerability, which could allow attackers to execute arbitrary code on the affected server.
PHP 5.4.5 < 5.4.23 OpenSSL openssl_x509_parse() Memory Corruption	high	7.5	PHP versions between 5.4.5 and 5.4.23 contain a memory corruption vulnerability in the OpenSSL openssl_x509_parse() function that could lead to denial of service or potential arbitrary code execution.
PHP 5.4.5 < 5.4.28 FPM Unix Socket Insecure Permission Escalation	high	7.2	PHP versions between 5.4.5 and 5.4.28 contain an insecure permission vulnerability in the PHP-FPM Unix socket that could allow local attackers to escalate privileges or gain unauthorized access to the system.

4. Risk Assessment

This report identifies security risks that could have significant impact on mission-critical applications used for day-to-day business operations.

Critical	High	Medium	Low	Info
12	13	20	7	101



Critical Severity Vulnerability

12 were unique critical-severity vulnerabilities. Critical vulnerabilities require immediate attention. They are relatively easy for attackers to exploit and may provide them with full control of the affected systems.

High Severity Vulnerability

13 were unique high-severity vulnerabilities. High severity vulnerabilities are often harder to exploit and may not provide the same access to affected systems.

Medium Severity Vulnerability

20 were unique medium-severity vulnerabilities. These vulnerabilities often provide information to attackers that may assist them in mounting subsequent attacks on your systems. These should also be fixed in a timely manner but are not as urgent as the critical vulnerabilities.

Low Severity Vulnerability

A total of low-severity vulnerabilities were identified during the assessment. These vulnerabilities generally pose minimal risk to the system and are unlikely to be directly exploited to compromise the system.



Informational Findings

A number of informational findings were identified during the assessment. These findings do not represent direct security vulnerabilities, but they provide useful information about the system configuration, services, and technologies in use.

5. Recommendations

Remediation:

Taking the following actions will resolve 96% of the vulnerabilities on the system:

Action to Take

- ☞ upgrade to a version of Canonical Ubuntu Linux that is currently supported
- ☞ Upgrade to ProFTPD 1.3.5a / 1.3.6rc1 or later.
- ☞ Upgrade to phpMyAdmin version 4.8.6 or later.
- ☞ Upgrade the Coder module to version 7.x-1.3 / 7.x-2.6 or later.
- ☞ Upgrade to the latest version of PHP that is currently supported
- ☞ Reconfigure the affected application if possible to avoid use of medium strength ciphers.
- ☞ disable IP forwarding by doing :
`echo 0 > /proc/sys/net/ipv4/ip_forward`
- ☞ Make sure that browsable directories do not leak confidential information or give access to sensitive resources. Additionally, use access restrictions or disable directory indexing for any that do.



☞ Return the X-Frame-Options or Content-Security-Policy (with the 'frame-ancestors' directive) HTTP header with the page's response. This prevents the page's content from being rendered by another site when using the frame or iframe HTML tags.

☞ Contact the vendor for an update with the strict key exchange countermeasures or disable the affected algorithms.

☞ Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digitally sign communications (always)'. On Samba, the setting is called 'server signing'.